Hao → Jerry：進版與 App Store 接續交接（2026-10-13）

本輪以 Jerry 548f0ec 為基底，接上 Hao 的 db94479（報名名單 / 跨分會管理）與 72016f8（日夜主題 / 檔案整理）。Hao 已批准直接併入 main。

Jerry 先看這幾點

1. 本輪沒有新增 migration，網站可沿用目前 RDS；不要重新執行 seed 或重建測試帳號。

2. /admin/roles 授權 payload 增加 organizationId，API 與前端要一起部署。

3. 報名者聯絡資料是管理者資料，不可併入一般會員的公開活動 API。

4. 跨分會依 Organization.parentId 展開；正式 DB 的區 / 複合區 / 分會父子關係若未建立，介面不會猜測授權範圍。

5. App Store 現在是「準備階段」：動態 Next.js 網站不能直接拿 .next 打包成原生 App，正式封裝與行動登入架構要另做。

已完成及 API 契約

活動報名名單

GET /api/events/[id]/registrations 回傳 { registrations: [{ id, registeredAt, member: { id, name, email, phone, title, photoUrl, organization: { name } } }] }，僅回傳 REGISTERED 狀態。

權限：活動建立者，或對主辦組織具 CLUB_OFFICER / CLUB_PRESIDENT / ZONE_ADMIN / DISTRICT_ADMIN / MULTIDISTRICT_ADMIN / SUPER_ADMIN 的管理者；與現有活動編輯資格一致。單有財務或副會長角色不會自動擴大活動管理權。

跨分會幹部管理

GET /api/admin/roles 回傳 organizations、organization、members、assignableRoles。指定 ?organizationId= 可切換所轄分會。

POST /api/admin/roles：

```
{
"organizationId": "目標分會 ID",
"memberId": "該分會啟用會員 ID",
"role": "CLUB_OFFICER"
}
```

伺服器驗證管理範圍、組織為啟用分會、會員屬於該分會，並擋重複角色。區級 / 複合區 / 全域角色仍由既有管理流程配置，前端不提供自授這些權限。

日夜主題與個人檔案

- 主題存於裝置 lion-theme；DB 不新增偏好欄位。新 UI 應用語意 token，見 日夜 UI 交接。
- 手機、生日可補填；入會年月空值仍由幹部補登，不開放會員自行修改會籍資料。
- 幹部工具入口依已有角色顯示；實際存取仍由後端判權限。
- 手機下拉選單背景 / 文字隨主題更新；保留自訂職稱，不讓表單默默改掉既有值。
- 本機預覽是合成資料，tmp/ui-preview.mjs 被 gitignore，未部署、也不連正式 DB。

部署後共同驗收

情境	預期
活動建立者查看報名名單	名稱、分會、日期、聯絡方式與正式資料一致
一般會員直呼 registrations API	403，不回傳其他會員聯絡資料
會長管理自己分會	僅能處理有權限的分會
區幹部切換分會	名單限實際所轄組織；修改 URL / payload 不能越權
撤銷其他分會角色	在管理範圍內可撤銷；範圍外 403；不可自撤
iPhone / Android 明暗模式	設定保存，原生日期 / 選單可讀，底部手勢區不遮擋
個人檔案未設定頭像	可儲存手機 / 生日，不因 photoUrl=null 格式被 API 擋下
斷線後儲存	顯示失敗訊息、保留內容，可重新送出

協作測試帳號

身分	帳號	密碼
示範會長	demo@lions.tw	demo1234
Hao	Hao@Lion.com	0204
Tom	Tom@Lion.com	0204
Jerry	jaijai0830@gmail.com	Jerry 的現用密碼

依 Jerry 10/13 交接記錄，以上帳號屬 AI臺科大獅子會。本輪未修改密碼、帳號或角色資料；Jerry 舊地址 Jerry@Lion.com 不再作為目前登入帳號。App Review 請另外建立受控、可完整走功能的專用審核帳號。

Jerry 的環境 / 後端接續

• 確認 events/* S3 PutObject IAM、照片 CORS、SES production access 與既有 migrations。

• 收斂 RDS 5432 安全群組；落實登入 / 註冊 / 忘記密碼速率限制與 Email 驗證。

• 實作 App 內帳號刪除與外部刪除入口：先定義活動歷史、帳號、S3 照片與資歷的處理，避免直接刪 Member 造成活動連帶刪除，或只留下沒有會員的登入帳號。

• 補伺服器 Session 撤銷與會員狀態檢查；現有 30 天 JWT 不因改密碼 / 只刪 User 而失效，登出只清目前 Cookie。帳號刪除 / 停權需驗收其他已登入裝置失去存取權。

• 實作真正的已好友封鎖 / 檢舉，且 QR 加好友不能繞過封鎖；規劃可追蹤的審核處理。

• 行動登入 / API 架構另定：現有 HttpOnly Cookie 同源行為可保留在網站，本機原生 WebView frontend 不可僅換 API 網址就假設 cookie 可用。

• 好友推薦排序、自動化權限/API 測試、新分會第一位管理者流程續做。

Hao / 上架負責人接續

• 確認正式 App 名稱、開發者實體、客服 Email、Apple Developer Team、Bundle ID、Logo 使用授權。

• 完成真正原生建置、相機與相簿權限、狀態列 / 主題同步、返回與鍵盤真機驗收。

• 準備最終 app icon、啟動畫面、真機商店截圖、App Privacy / 年齡分級與 Review Notes。

• 商店文案與待補欄位在 App Store 準備包；目前機器只有 Command Line Tools，須安裝完整 Xcode 26 或之後的版本才能接續 Archive / TestFlight。

驗證與資料狀態

TypeScript、production build、手機版 UI 已完成本機驗證。真實 API / 組織範圍、AWS 部署與原生 IPA 尚待對應環境驗收。本輪沒有讀寫正式 DB、執行 migration 或變更 AWS 設定。

App Store 送審前必補（共同）

1. 確認品牌 / 開發者資料及 Apple Developer Team，安裝完整 Xcode 26+；本輪尚未產生已簽章 IPA 或上傳 TestFlight。

2. 完成公開隱私政策、客服支援與刪除入口；App 內能提出完整帳號刪除，不能只有停用或要求寄信。資料保留與刪除期限由負責實體確認。

3. 完成個人頁等會員內容的檢舉與好友封鎖，QR 加好友不得繞過封鎖；提供實際可用的聯絡管道與處理流程。

4. 決定正式原生架構與行動登入契約，確認相機 / 相簿 / 安全區 / 系統返回 / 鍵盤。Capacitor 的 server.url 是開發用途設定，不作為正式封裝方案。

5. 製作真機截圖、App Privacy 揭露、年齡分級、品牌素材與審核專用帳號；逐一驗收後才進 TestFlight，再送審。

官方參考：Apple 送審規範、帳號刪除要求、SDK 要求。